

APPLIED CRYPTOGRAPHY SECURITY ASSESSMENT

Cryptographic Failure Analysis & Security Control Mapping

Portfolio Project

Executive Summary

This assessment evaluated the implementation of cryptographic controls within a simulated enterprise environment. The review focused on encryption practices, key management, authentication token security, and cryptographic standards compliance.

Multiple weaknesses were identified, including exposed cryptographic material, IV reuse, weak JWT signing secrets, missing token validation controls, and the use of insecure cryptographic mechanisms. Recommendations were developed using NIST, RFC, and FIPS guidance to improve confidentiality, integrity, and access control.

Crypto Failure Mapping

The primary security issue identified during this assessment was the incorrect implementation of cryptographic controls. Encryption should be used to protect information that must be recovered later, while hashing should be used for data that should never be reversible. Although AES encryption was implemented, its effectiveness was significantly reduced because the encryption key and Initialization Vector (IV) were stored within the same configuration source. A more secure design would separate cryptographic secrets into a dedicated key management solution and apply strong hashing mechanisms where appropriate to protect sensitive information.

Crypto Failure Mapping Table

#	Finding	Standard Mapping	Risk
1	Exposed AES Cryptographic Material	NIST SP 800-57 Part 1 (Sections 6.2 & 8.3: Key Management Principles)	Storing encryption keys and initialization vectors alongside protected data eliminates confidentiality controls and allows unauthorized decryption of sensitive information.

2	IV Reuse in AES-CBC Implementation	NIST SP 800-38A (Appendix B: IV Requirements for CBC Mode)	Reusing the same IV across encryption operations weakens semantic security and enables pattern analysis that may reveal relationships between encrypted data.
3	Weak JWT HMAC Secret (HS256)	RFC 7518 (Section 3.2: HMAC Key Requirements)	Weak signing secrets are vulnerable to brute-force attacks, allowing attackers to forge authentication tokens and potentially gain unauthorized access.
4	JWT Algorithm Confusion / "None" Acceptance	RFC 7519 (Section 7.2: JWT Validation Requirements)	Failure to enforce algorithm validation permits unsigned tokens, enabling authentication bypass and unauthorized privilege escalation.
5	Missing Token Expiration (No exp Claim)	RFC 7519 (Section 4.1.4: Expiration Time Claim)	Tokens remain valid indefinitely, increasing the risk of replay attacks and prolonged unauthorized access if credentials are compromised.
6	Missing Audience Validation (aud Claim Absent)	RFC 7519 (Section 4.1.3: Audience Claim)	Tokens may be reused across different applications or environments, increasing the likelihood of cross-system impersonation and unauthorized access.
7	Insecure Cryptographic Primitive (ROT13 Usage)	FIPS 140-3 (Approved Cryptographic Algorithms Requirement)	Non-secure encoding mechanisms provide no meaningful confidentiality protection and may create a false sense of security.

Summary

This assessment identified multiple critical cryptographic weaknesses across encryption implementation, token management, and legacy encoding mechanisms. The issues include improper key and IV management, weak secret generation practices, missing JWT security controls, and the use of insecure encoding techniques. Collectively, these weaknesses undermine confidentiality, integrity, and trust boundaries, increasing the likelihood of decryption, token forgery, unauthorized access, and cross-system misuse.

Security Control Recommendations

To remediate the identified weaknesses in a practical and cost-effective manner, the organization should focus on implementing the following security controls.

#	Control(Specific)	Addresses Finding(s)	One sentence justification
1	Migrate to AES-256-GCM with centralized key management	Exposed AES Material, IV Reuse	Managed keys and authenticated encryption eliminate hardcoded secrets and prevent ciphertext tampering or IV misuse.
2	Enforce strict JWT validation using open-source libraries (block none, enforce exp and aud)	Unsigned JWT, No Expiration	Strong validation ensures tampered, unsigned, or expired tokens are rejected before reaching application logic.
3	Implement environment-specific JWT audience validation (aud claim enforcement)	Scope Creep, Unsigned JWT	Restricting tokens to specific environments prevents cross-system token replay and privilege escalation.
4	Replace weak secrets with 256-bit environment-injected cryptographic keys	Weak JWT Secret, No Expiration	Strong random keys stored securely in environment variables prevent brute-force attacks and token forgery.
5	Standardize HMAC-SHA256 for integrity and replace insecure encodings (e.g., ROT13)	Broken Algorithm, Weak JWT Secret	Using proper cryptographic hashing ensures data integrity and removes reversible or insecure encoding methods.

Summary

The recommended controls directly address the cryptographic weaknesses identified during the assessment. By improving encryption standards, strengthening key management practices, enforcing secure token validation, and eliminating insecure mechanisms, the organization can significantly reduce the risk of unauthorized access, token forgery, and data compromise.

Ethical Consideration: Confidential Disclosure Request

During the course of this assessment, I received a request from an external stakeholder seeking early access to assessment findings before they were formally presented through the approved reporting process. While such requests may appear beneficial from a networking or collaboration perspective, they raise significant concerns regarding confidentiality, professional responsibility, and proper disclosure procedures.

In evaluating this situation, I would consult only authorized personnel within the defined governance structure of the engagement. This includes the assigned program supervisor and any designated ethics, compliance, or oversight representatives. Findings would not be shared with external parties outside the approved reporting chain regardless of perceived influence or professional relationships.

The information I would be willing to disclose is limited strictly to content formally approved for release through authorized channels. Raw evidence, decrypted artifacts, exploit details, or sensitive technical findings would not be shared before official review and approval.

My primary obligation is to the integrity of the assessment process and the protection of sensitive information. Ethical cybersecurity practice requires prioritizing confidentiality, integrity, and authorization requirements over informal requests or external pressure.

According to the (ISC)² Code of Ethics, Canon 2 states: "Act honorably, honestly, justly, responsibly, and legally." Premature disclosure of sensitive findings would violate these principles and undermine trust in the assessment process.

The appropriate action would be to document the request and report it through the designated supervisory channels. This ensures transparency, protects all stakeholders, and maintains compliance with ethical and professional cybersecurity standards.

Core Competencies

- Applied Cryptography
- Cryptographic Risk Assessment
- JWT Security Analysis
- Authentication & Access Control
- Key Management
- Security Architecture Review
- Security Control Design

- Risk Analysis
- NIST Standards Alignment
- RFC Compliance Mapping
- Technical Reporting
- Ethical Security Practice